Udyam Digital: data privacy and security choices

Accel Business onboarding prototype · Team Ticchi Gang (Monis, Team Leader; Ubesh Siddiqui) · NSUT Delhi · YTL Hackathon 2026, Track A

Designed to align with the DPDP Act 2023 · all data synthetic

1. Purpose and consent

- No registry lookup, document check or DigiLocker request runs before the owner gives **consent for one stated purpose** (verify the business for this connection).
- Consent is stored with its purpose, scope, notice version and language, and **expires after 30 minutes**.
- **Withdrawal** ends consent and erases everything not yet verified: registry results, documents, stored files and ownership checks. An officer's rejection stays on record.

2. Data minimisation

- Each step collects only the fields it needs; identifiers are never asked for in chat.
- With DigiLocker, documents are **pulled from the issuer and verified**; we keep the extracted fields and the signature result, not copies of the files.
- Aadhaar: only the **last 4 digits** and a keyed reference (to stop one Aadhaar being used by two owners) are kept, never the number. Names come from the issuer, not from what is typed.

3. Masking and encryption

- GSTIN and Udyam numbers are **encrypted at rest (AES-256-GCM)**; lookups and duplicate checks use **keyed HMAC** hashes. PAN and bank account are stored masked plus HMAC.
- Identifiers are masked on every screen and never written to the audit log (record IDs only).
- Documents are private: served only to the owner and KYC or ops staff, with a no-execute content policy; every staff view is audited.

4. AI safeguards

- GSTIN, PAN, Aadhaar, phone and e-mail typed into chat are **redacted before any text reaches Gemini**.
- The AI only fills structured, schema-validated profile fields; **the rules engine decides every product and price**, and every order line is re-validated on the server. AI never decides KYC.
- Documents are read twice on our server (OCR and an AI reader); disagreement or signs of editing send them to a person. Fallback: lighter model, then local rules.

5. Fraud controls

- **Proof of control**, not just existence: the registration in the applicant's own DigiLocker, or business PAN plus a ₹1 bank check returning the business name.
- **Hard stops** no one can override: cancelled or suspended GSTIN; GSTIN, Udyam, Aadhaar or bank already verified for another owner; failed issuer signature.
- **Maker-checker**: officers must open every document, give a reason per override, and a second officer confirms. Technician **GPS check-in** gates activation.

6. Retention and deletion

- Owners can request **access or erasure** in the app; requests carry a **30-day** due date in the ops queue.
- Erasure deletes KYC data and files; it is refused only where a live connection must keep subscriber KYC for the telecom licence period.
- Replaced documents stay on record for audit until erasure. *Planned: scheduled purge of unverified data and a written retention schedule.*

7. Security

- Session in an **httpOnly, SameSite cookie** (Secure in production); **CSRF origin check** on every state change; **rate limits** on OTP, Aadhaar and DigiLocker steps; OTPs hashed, single-use, 5 attempts.
- Uploads checked by **file signature** (JPEG, PNG, WebP, PDF only, 10 MB). Payment and e-sign are **idempotent**: a double tap never applies twice.
- Secrets only in environment variables; the server refuses to start in production with weak secrets.

8. Audit and accountability

- Every consent, lookup, upload, document view, officer decision and override is logged with actor, role and time.
- Officer overrides record the reason code and both officers.
- *Planned: hash-chained, append-only audit store; breach-response runbook with CERT-In reporting.*

What is simulated today, and what production needs

Simulated: DigiLocker (OAuth 2.0 + PKCE flow and issuer signatures are real logic), UIDAI e-KYC, GSTN, Udyam and Protean PAN lookups, bank penny-drop, e-sign OTP, UPI and WhatsApp. Production: DigiLocker Requester access via API Setu or a licensed KYC provider; Aadhaar e-KYC through a licensed AUA/KUA; a GST Suvidha Provider; Aadhaar eSign through an eSign provider; an RBI-licensed payment aggregator; DLT-registered SMS; India-region hosting; processor agreements (including the AI provider, named in the notice) and an enterprise AI tier.

All businesses, people and identifiers are synthetic (case pack). This note describes the prototype as built; items marked planned are not yet implemented.
Team Ticchi Gang · Monis (Team Leader), Ubesh Siddiqui · NSUT Delhi.